Fiche technique — à l'attention du service informatique et du responsable de la sécurité informatique

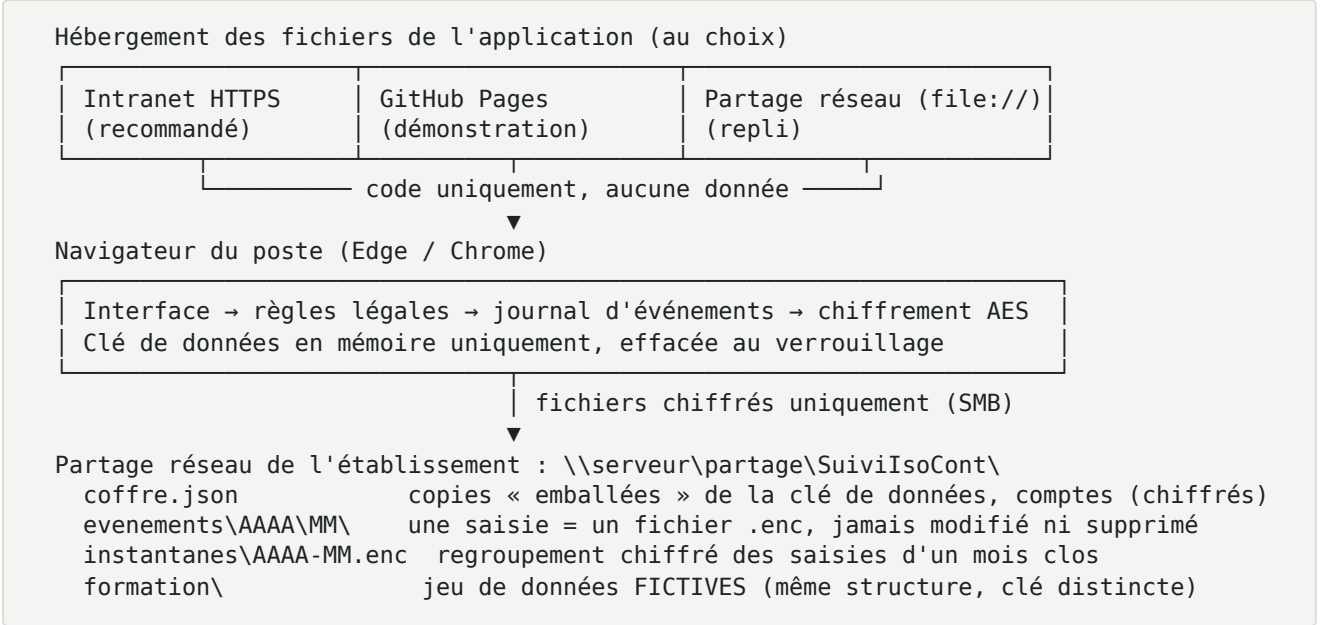
Destinataires : le service informatique (DSI ou direction du numérique, selon l'établissement) et le responsable de la sécurité informatique (RSSI).

Suivi-mesures-isocont 1.0 — application web statique, données chiffrées sur un partage réseau de l'établissement. Licence EUPL-1.2. Code source : https://github.com/rodtrip2/Suivi-mesures-isocont

1. Résumé

Élément	Choix technique
Type d'application	Page web statique (HTML, CSS, JavaScript), sans serveur applicatif, sans base de données, sans étape de construction
Dépendances	Aucune bibliothèque externe ; uniquement les API standard du navigateur
Stockage	Dossier d'un partage réseau (SMB) choisi par l'utilisateur, accédé par l'API *File System Access* du navigateur
Chiffrement	AES-GCM 256 bits côté poste (Web Crypto API) ; chiffrement en enveloppe
Authentification	Comptes nominatifs ; mot de passe (PBKDF2-SHA-256, 600 000 itérations), clé de sécurité FIDO2 (WebAuthn, extension PRF) ou code de secours ; mot de passe provisoire à changer obligatoirement à la première connexion
Flux réseau	**Aucun flux sortant** : politique de sécurité du contenu `connect-src 'none'` ; seul le chargement des fichiers de l'application depuis l'hébergement choisi
Navigateurs	Microsoft Edge ou Google Chrome récents (Chromium). Firefox et Safari : mode démonstration uniquement
Postes	Windows 10/11 (ou tout système avec Edge/Chrome) ; aucun logiciel à installer
Volumétrie	Environ 1 à 2 Ko par saisie ; ordre de grandeur : quelques dizaines de Mo par an pour une unité

2. Architecture



Modes d'hébergement

Critère	Intranet HTTPS	GitHub Pages	Partage réseau (`file://`)
Mise en place	Serveur web existant (IIS, Apache, nginx)	Immédiate	Copie de fichiers
Accès Internet requis	Non	Oui (chargement du code)	Non
Clés de sécurité (WebAuthn)	Oui (nom de domaine et certificat valides)	Oui	Non
Maîtrise de la version	Service informatique	Mainteneurs du projet	Service informatique
Usage conseillé	**Production**	Démonstration, données fictives	Repli

Une clé de sécurité est liée au nom de domaine du site : elle doit être enregistrée dans chaque mode utilisé. Le mot de passe et le code de secours fonctionnent partout.

3. Prérequis

Postes

- Edge ou Chrome dans une version récente, avec l'API *File System Access* (présente depuis la version 86) et l'extension WebAuthn PRF pour les clés matérielles (Chrome 116 et suivants).
- Accès en lecture et écriture au dossier de données, via un lecteur réseau ou un chemin UNC.
- À chaque nouvelle session, le navigateur peut redemander l'autorisation d'accéder au dossier : c'est un comportement normal.
- Si le site est hébergé sur l'intranet, aucune extension de navigateur ne doit injecter de script dans la page (politique de sécurité stricte).

Clés de sécurité (optionnel, recommandé pour l'administration)

- YubiKey série 5 (FIDO2, fonction *hmac-secret*), micrologiciel 5.2 ou plus récent, ou toute clé FIDO2 compatible PRF.
- Ports USB autorisés pour les clés de sécurité par la politique de l'établissement.
- Sous Windows, la prise en charge de PRF dépend de la version du système et du navigateur : **test obligatoire sur un poste type**.

Serveur web (mode intranet)

- Service de fichiers statiques en HTTPS avec certificat reconnu par les postes.
- En-têtes recommandés (la page déclare déjà sa politique de sécurité dans une balise `meta`) :
- `Content-Security-Policy: default-src 'none'; script-src 'self'; style-src 'self'; img-src 'self' data:; manifest-src 'self'; connect-src 'none'; form-action 'none'; base-uri 'none'; frame-ancestors 'none'`
- `X-Content-Type-Options: nosniff`, `Referrer-Policy: no-referrer`
- `Cache-Control: no-cache` sur `index.html` et les scripts, pour que les postes prennent une mise à jour sans délai.

4. Dossier de données et droits

- Créer un dossier dédié, par exemple `\\serveur\donnees\SuiviIsoCont`, **un par périmètre de confidentialité** (un établissement, un pôle).
- Donner les droits NTFS **Modifier** au groupe des agents utilisateurs (IDE, secrétariat, cadres), **aucun droit** aux autres. Le navigateur écrit un fichier temporaire puis le renomme : création, écriture et suppression du temporaire doivent être permises.
- L'application ne supprime jamais un fichier de données. Une suppression manuelle est détectée lorsqu'elle crée un trou dans la chaîne des saisies d'un poste, et les sauvegardes permettent de restaurer le fichier.
- Les droits Windows sont une seconde barrière, indépendante du chiffrement : un fichier copié hors du dossier reste illisible sans moyen de déverrouillage.

5. Cryptographie

Élément	Mise en œuvre
Clé de données	AES-GCM 256 bits, tirée au hasard à l'initialisation (`crypto.subtle.generateKey`)
Chiffrement d'un fichier	En-tête `SIC1` + IV aléatoire de 96 bits + texte chiffré authentifié ; données associées = nom du fichier (un fichier renommé ou échangé est rejeté)
Emballage par mot de passe	PBKDF2-SHA-256, 600 000 itérations, sel aléatoire de 128 bits par emballage
Emballage par clé de sécurité	Secret WebAuthn PRF (*hmac-secret*) calculé dans la clé, dérivé par HKDF-SHA-256
Code de secours	20 caractères tirés au hasard (100 bits d'entropie), PBKDF2-SHA-256, 100 000 itérations

Élément	Mise en œuvre
Mot de passe provisoire	16 caractères tirés au hasard (80 bits d'entropie), PBKDF2-SHA-256, 100 000 itérations ; remplacé à la première connexion par un mot de passe personnel (600 000 itérations). Un mot de passe provisoire saisi à la main par l'administrateur reçoit 600 000 itérations
Comptes et rôles	Chiffrés dans `coffre.json` avec la clé de données
En mémoire	Clé non exportée vers le stockage du navigateur ; effacée au verrouillage, à la fermeture de l'onglet et après inactivité (10 minutes par défaut)
Écriture du coffre	Contrôle de révision : une modification concurrente est refusée plutôt qu'écrasée

Chaque agent a sa propre copie emballée de la clé de données. Désactiver un compte supprime sa copie : son mot de passe ne déverrouille plus rien. Réinitialiser un mot de passe remplace la copie de l'agent : l'ancien mot de passe cesse aussitôt de fonctionner. Les mots de passe ne figurent jamais dans le journal.

6. Saisie simultanée et intégrité

- **Une saisie = un fichier**, nommé par l'horodatage, l'identifiant de l'agent et un aléa. Deux saisies simultanées ne peuvent pas s'écraser.
- L'état est reconstitué en relisant le journal ; les postes relisent les nouveaux fichiers toutes les 5 secondes.
- **Conflits** : deux modifications concurrentes de la même donnée d'une mesure (par exemple deux fins saisies en même temps) sont détectées. La première est appliquée, la seconde est conservée et signalée pour arbitrage par un cadre. Rien n'est perdu.
- **Corrections et annulations** : ce sont de nouvelles saisies, avec leur motif. L'historique reste intact.
- **Instantanés** : les saisies d'un mois clos sont regroupées dans un fichier chiffré `instantanes\AAAA-MM.enc`, lu en une fois. Les fichiers d'origine restent en place et font foi ; le dossier `instantanes` peut être supprimé sans perte (il est reconstruit).
- Chaque saisie référence la précédente du même agent (chaînage) ; chaque agent laisse un **repère** chiffré (`reperes\<agent>.enc` : nombre de ses saisies, dernière saisie), dont le compteur ne recule jamais. Le contrôle d'intégrité (connexion, puis toutes les 15 minutes) signale les saisies disparues, les fichiers illisibles et les trous du chaînage.
- **Dossier des exports** (`exports\` par défaut, réglable par l'administrateur, toujours à l'intérieur du dossier des données) : décomptes JLD, registres, statistiques, registres pour communication, données d'un patient et archives y sont écrits **en clair** (PDF, CSV), rangés par service puis par catégorie (`exports\<code du service>\<catégorie>`, `exports\Etablissement` pour les exports multi-services) — ce qui permet, si l'établissement le souhaite, des droits NTFS par service sur ces sous-dossiers —, jamais écrasés ; chaque export est tracé au journal. Ce dossier hérite des droits NTFS du dossier des données, est sauvegardé avec lui, et relève de la durée de conservation fixée par l'établissement : réglage *Durée de conservation des exports* (aucune purge par défaut ; de 1 mois à 5 ans), purge automatique à la première connexion de la journée sur chaque poste (date de modification des fichiers), tracée au journal ; suppression manuelle par l'administrateur, tracée. Les copies de sauvegarde et les mots de passe provisoires ne sont jamais écrits sur le partage. **Accès direct depuis Windows** : l'administrateur peut renseigner le chemin réseau du dossier des données (UNC ou lecteur) ; l'outil affiche alors le chemin de chaque dossier d'exports et propose un raccourci Windows (.url, `file://…`) à placer sur le bureau. Le service

informatique peut déployer ce raccourci par stratégie de groupe ; un navigateur ne peut pas ouvrir l'Explorateur de lui-même.

- **Préférences d'affichage** (thème clair ou sombre) : un petit fichier chiffré par agent, `preferences\<agent>.enc`, sans donnée de patient ni trace au journal ; sa perte ramène simplement l'affichage par défaut. Le dernier choix du poste est aussi gardé dans le navigateur (`localStorage`, clé `sic-theme`) pour l'écran de connexion.
- **En cas d'anomalie**, l'administrateur transmet au service informatique la liste des fichiers (chemins relatifs `evenements\AAAA\MM\<nom>.enc`), à restaurer **à l'identique, au même chemin**. L'outil peut aussi réparer depuis une copie de sauvegarde complète : il ne remet que les fichiers absents ou illisibles, vérifiés avec la clé de l'établissement. Les fichiers illisibles peuvent être déplacés dans `quarantaine\AAAA\MM\` (jamais supprimés). Ces dossiers sont à sauvegarder avec le reste.

Mode formation

- Le jeu de formation est un second jeu de données, entièrement fictif, dans le sous-dossier `formation` du dossier principal (mêmes droits NTFS, même sauvegarde). Il est chiffré avec **sa propre clé** AES-256, elle-même rangée dans `coffre.json`, chiffrée par la clé des données réelles : seul un agent connecté avec son vrai compte peut l'ouvrir.
- À la connexion, l'agent choisit *Données réelles* ou *Mode formation*. L'accès au mode formation est accordé à chaque compte par défaut et désactivable par l'administrateur. En formation, l'agent garde son compte, ses rôles et ses services ; les comptes, mots de passe et clés restent ceux du coffre réel. Le code de secours ouvre toujours les données réelles.
- Les données réelles et fictives ne se mélangent jamais : une saisie en formation est écrite dans `formation\` avec la clé du jeu de formation. Les opérations sur les comptes (changement de mot de passe, activation du mode formation) sont tracées dans le journal réel.
- Le sous-dossier `formation` peut être supprimé sans perte de données réelles ; il ne peut pas être ouvert comme dossier principal (l'application le détecte et le refuse).

7. Sécurité applicative

- Politique de sécurité du contenu stricte : aucun script externe, aucune requête réseau, aucun formulaire envoyé.
- Interface construite sans interprétation HTML des données saisies (pas d'`innerHTML`) : pas d'injection de script par une donnée.
- Aucune donnée patient conservée dans le navigateur après fermeture ; seuls le dernier dossier ouvert et le service affiché sont mémorisés localement.
- Code public, sans minification, relisible. Une empreinte SHA-256 de chaque fichier est publiée avec chaque version (`app/EMPREINTES-SHA256.txt`).

Modèle de menace

Menace	Couverture
Vol ou copie du dossier de données	Données chiffrées ; inexploitables sans moyen de déverrouillage
Lecture par un agent sans droit sur le partage	Droits NTFS ; chiffrement

Menace	Couverture
Agent autorisé outrepassant son rôle	Rôles appliqués par l'interface ; toute saisie est nominative, chaînée et visible dans le journal. **Sans serveur, le contrôle des rôles n'est pas inviolable** : un utilisateur techniquement compétent disposant d'un compte valide pourrait le contourner, mais pas sans laisser de trace
Altération d'un fichier	Rejetée (chiffrement authentifié) et signalée
Code de l'application modifié	Hébergement intranet maîtrisé, empreintes SHA-256, politique `connect-src 'none'` empêchant l'exfiltration par le réseau
Poste compromis (enregistreur de frappe, etc.)	Hors périmètre de l'application : relève de la sécurité du poste
Perte de tous les moyens de déverrouillage	Données irrécupérables par conception : procédure de secours (deux clés, code papier)

8. Sauvegarde et restauration

- Sauvegarder le dossier comme tout partage de fichiers ; les sauvegardes sont chiffrées de fait.
- Restaurer = remettre les fichiers en place. Les fichiers de saisie sont indépendants : une restauration partielle ne corrompt pas le reste.
- `coffre.json` est indispensable : sans lui, aucune donnée n'est lisible. Il doit figurer dans chaque sauvegarde.
- Tester une restauration lors de la recette, puis une fois par an.

9. Mise à jour et vérification

1. Télécharger la version (dépôt GitHub, étiquette de version).
2. Vérifier les empreintes : `Get-FileHash -Algorithm SHA256 .\app\js\*.js` (PowerShell) et comparer avec `app/EMPREINTES-SHA256.txt` publié.
3. Remplacer le dossier `app` sur le serveur web. Les données ne sont pas touchées.
4. Le format des données est versionné : une nouvelle version lit les données des versions antérieures.
5. Lancer les tests automatiques si besoin (`npm test` , Node.js 20 ou plus récent, sur un poste de développement).

10. Conformité

Sujet	Analyse	À valider par
Hébergement de données de santé (art. L. 1111-8 code de la santé publique)	Les données restent sur l'infrastructure de l'établissement, sans prestataire. La certification d'hébergeur de données de santé (HDS) s'impose à qui propose un service d'hébergement ; elle ne devrait donc pas s'appliquer ici, mais tout projet doit être examiné au cas par cas (Agence du numérique en santé). Avec GitHub Pages, seul le code est servi par GitHub.	Délégué à la protection des données (DPO, référent RGPD), service informatique

Sujet	Analyse	À valider par
RGPD	Traitement à inscrire au registre ; analyse d'impact probablement requise (liste CNIL). Éléments pré-remplis : document 05 du kit.	Délégué à la protection des données (DPO, référent RGPD)
Registre légal (art. L. 3222-5-1 code de la santé publique)	L'outil produit le registre ; son statut de support officiel relève d'une décision de l'établissement.	Direction
Politique de sécurité	Navigateurs, clés USB, droits du partage, journalisation.	Responsable de la sécurité informatique

11. Limites connues de la version 1.0

- Pas de rotation automatique de la clé de données (désactiver un compte suffit pour un départ ; voir les procédures de secours).
- Contrôle des rôles côté poste (voir le modèle de menace).
- Pas d'interface avec le dossier patient informatisé (DPI) : les décisions médicales y sont reportées manuellement.
- Pas de notification hors de l'application (courriel, SMS) : les alertes s'affichent à l'ouverture.
- Firefox et Safari ne permettent pas d'ouvrir un dossier réseau.

12. Recette technique — liste de contrôle

- ☐ Empreintes SHA-256 des fichiers vérifiées.
- ☐ Application servie en HTTPS sur l'intranet ; certificat reconnu par les postes.
- ☐ Dossier de données créé ; droits NTFS limités au groupe des utilisateurs.
- ☐ Poste type : ouverture du dossier, initialisation, saisie, relecture depuis un second poste.
- ☐ Saisie simultanée depuis deux postes : aucune perte, conflit signalé.
- ☐ Clé de sécurité enregistrée puis utilisée pour déverrouiller (si retenue).
- ☐ Sauvegarde puis restauration du dossier testées.
- ☐ Vérification qu'aucune requête sortante n'est émise (outils de développement, onglet Réseau).
- ☐ Mode formation : une connexion en mode formation n'affiche que les données fictives ; un compte dont l'accès est désactivé est refusé ; une connexion en données réelles n'affiche aucune donnée fictive.